

Information Security Policy

Owner: Bar Elezra, Head of Information Security
Contact: security@pennylime.com
Effective date: April 1, 2026
Last reviewed: April 29, 2026
Review cadence: Annual, or upon material change to the business or technology stack.
Public copy: <https://pennylime.com/security>

PennyLime, operated by 770 Technology Way LLC, a Florida limited liability company, maintains this Information Security Policy to govern the confidentiality, integrity, and availability of information assets entrusted to us by merchant applicants, customers, employees, partners, and regulators. This policy is binding on all personnel, contractors, and service providers acting on behalf of PennyLime.

1. Scope

This policy covers all information assets owned, processed, or controlled by PennyLime, including production systems, customer data, employee records, source code, third-party integrations (Plaid, Twilio, Railway, Cloudflare, Google Workspace, payment processors), and physical and remote work environments used by personnel.

2. Governance and Roles

The Head of Information Security is the policy owner and is accountable for security strategy, policy, and incident response. The Founder serves as the executive sponsor. All personnel are responsible for following this policy and reporting suspected security events. Vendors and contractors are bound by written agreements that include confidentiality and security requirements.

3. Data Classification and Handling

Information is classified into four levels:

- **Restricted** — Social Security numbers, government IDs, encrypted bank credentials, payment authorization data, full transaction histories.
- **Confidential** — Personally identifiable information (PII) including names, addresses, phone numbers, dates of birth, employer information, and consumer-report data.
- **Internal** — Business records, source code, internal documentation, vendor contracts.
- **Public** — Marketing content, published policies, public website material.

Handling, retention, and destruction requirements scale to the classification level. Restricted and Confidential data are encrypted at rest and in transit, access-logged, and retained only for the loan or advance lifecycle plus regulatory retention windows, after which data is securely destroyed.

4. Access Control and Authentication

Access to production systems, customer data, and administrative tools follows the principle of least privilege. All administrative accounts require multi-factor authentication. Access is granted upon documented business need, reviewed at least quarterly, and revoked within one business day of role change or separation. Shared credentials are prohibited. Production database access is logged and audited.

5. Encryption Standards

Restricted and Confidential data are encrypted at rest using AES-256 and in transit using TLS 1.2 or higher. Cryptographic keys and secrets are stored in a managed secrets store (Railway environment variables and equivalent), rotated upon personnel change, and never embedded in source code. Sensitive fields stored in our application database (e.g., SSN, Plaid access tokens) are individually encrypted with application-layer keys.

6. Network and System Security

Production infrastructure runs on hardened, reputable cloud providers (Railway, Cloudflare). Public services are served exclusively over HTTPS. Web application firewalling, rate limiting, and bot mitigation are provided by Cloudflare. Application code is reviewed before deployment. Dependencies are continuously monitored for known vulnerabilities and patched on a defined cadence.

7. Vendor and Third-Party Risk Management

All service providers handling Restricted or Confidential data are reviewed for security posture before engagement and are bound by written agreements requiring confidentiality, breach notification, and applicable regulatory compliance (GLBA, FCRA, BSA/AML, FDCPA, NACHA, PCI-DSS where applicable). Material vendors are reviewed at least annually. The current set of in-scope vendors includes Plaid (account data and verification), Twilio (SMS), Railway (compute and database), Cloudflare (network and DNS), and Google Workspace (email).

8. Personnel Security and Training

Personnel with access to Restricted or Confidential data acknowledge this policy in writing and complete security awareness training at onboarding and at least annually thereafter. Training covers phishing, credential hygiene, data handling, incident reporting, and applicable regulatory obligations. Background checks are conducted for personnel with access to Restricted data, where lawful.

9. Secure Software Development

Code is version-controlled in Git with branch protection. Production deploys go through automated build and dependency checks. Secrets are never committed to source control. Material schema or security-impacting changes are reviewed by the policy owner before release.

10. Incident Response

PennyLime maintains a documented Incident Response Plan covering detection, triage, containment, eradication, recovery, and post-incident review. Suspected security events are reported to security@pennylime.com. Incidents involving customer data are triaged within 24 hours and material incidents are reported to affected parties and regulators within applicable statutory timelines. Post-incident reviews produce written remediation plans owned by the Head of Information Security.

11. Business Continuity and Disaster Recovery

Production data is replicated and backed up by our infrastructure providers. Recovery objectives are reviewed at least annually. Critical operational runbooks are maintained for service interruption, vendor outage, and data loss scenarios.

12. Privacy and Regulatory Compliance

PennyLime complies with the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule, the Fair Credit Reporting Act (FCRA) and Regulation V where consumer-report data is used, the Bank Secrecy Act (BSA) and AML obligations including OFAC and PEP screening, the Fair Debt Collection Practices Act (FDCPA) and Regulation F for any collections activity, NACHA Operating Rules for ACH transactions, and applicable state privacy and consumer protection laws including the CCPA/CPRA for California residents.

13. Audit, Monitoring, and Logging

Authentication events, administrative actions, and material data access are logged. Logs are retained for at least one year and reviewed periodically and upon trigger events. Security exceptions and policy deviations are documented and tracked to remediation.

14. Policy Review and Acknowledgment

This policy is reviewed annually, or sooner upon material change to the business, technology stack, or regulatory environment. Updates are versioned and dated. All personnel acknowledge the current policy at hire and at each annual review.